

DROS-PGM: 針對自主 AI 工作負載之後受陷約束 確定性執行邊界 (v2.0)

陳濤程 (Chun-Cheng / Jimmy Chen)
康宸園有限公司 (Top-Celestial Company Ltd.)
台灣台北市
jimmychen@dr-os.io

Abstract—在自主 AI 代理獲取合法憑證與工具調用權限的現代工作負載中，應用層安全邊界正面臨根本性失效。傳統防禦體系主要依賴機率性語義護欄或粗粒度作業系統沙箱，其核心假設建立於「防範受陷」之上；然而，一旦內部對話或直譯器遭遇提示注入或邏輯受陷，攻擊者即可繼承合法憑證並引發不可逆的實體副作用。本文提出 DROS-PGM，一種運行於二進位執行控制平面之後受陷執行約束基板。在架構上，C-ABI / FFI 邊界負責策略調用與主體能力歸因，而 OS 內核 Hook 則在顯式插樁之受管操作類別空間 $X_{covered}$ 上執行強制授權檢查。PGM 將應用層主體身分與底層執行授權實體解耦，透過亞微秒級（中位數 353 ns）無鎖策略評估與原子化 RCU 狀態指針切換，形式化維持安全不變量。為嚴謹評估此邊界，我們引入 PGM-VEP 五階漸進式對抗證偽方法學（V1-V5），涵蓋攻擊等價基準對照、白箱對抗探針搜尋、陰性對照組元驗證（5/5 缺陷捕獲與 100/100 突變殺死率）、四階段解耦判定神諭（ $O_I \rightarrow O_A \rightarrow O_E \rightarrow O_P$ ）以及跨 Linux x86_64、ARM64 與 Windows 異質環境之獨立自動化復現。在累積 68,355 次對抗與驗證執行負載及 50,000 次良性基準負載（總計 118,355 次執行，良性誤拒率 BFDR = 0/50,000）中，於顯式插樁觀測邊界內未曾觀測到任何授權逃逸或實體狀態漂移。本文將所得保證確立為經驗不變量而非全域安全證明，並公開發布反例登錄協議以供學術社群持續進行開放式對抗證偽。

Index Terms—執行約束基板，後受陷安全，內核強制邊界，動態能力撤銷，漸進式對抗證偽，解耦判定神諭。

I. 問題定義：AGENT 受陷不等於執行權限

當代自主 AI Agent 系統普遍獲得執行實體操作之特權。在此架構下，系統安全面臨著根本性的語義與內核斷層 (The Semantic-Kernel Paradox)：

- 1) 語義應用中介軟體 (高語義，零確定性)：提示防火牆與 JSON 模式驗證器僅能在自然語言層面進行機率性評估，欠缺執行邊界物理圍阻能力。
- 2) 作業系統內核沙箱 (高確定性，零語義)：傳統內核防禦具備二進位級強制力，但完全欠缺應用層語義上下文，無法區分合法財務 Agent 與已受陷之客服 Agent。

此斷層導致嚴重的「主體身分與執行權限混淆」。本文確立核心研究命題：應用層主體受陷，不得自動繼承無限制之底層執行權限 ($C_A \not\Rightarrow C_E$)。

II. 雙重邊界與系統分工

本架構確立「C-ABI 歸因」與「內核強制」的雙重邊界模型：

專利聲明：DROS 執行治理與安全技術已申請美國臨時專利保護 (U.S. Patent Application No. 64/111,973, Patent Pending)。永久學術文獻引用：Zenodo Record DOI: 10.5281/zenodo.21903687。開源存證靶場：<https://github.com/Top-Celestial-Company-Ltd/DROS-VEP-lite>。

- 邊界一 (C-ABI / FFI 歸因邊界)：負責策略調用與主體能力歸因，以 $O(1)$ SIMD 點陣圖在 353 ns 內完成判定。
- 邊界二 (OS 內核強制邊界)：於顯式插樁之受管操作空間 $X_{covered}$ 執行二進位攔截。

受管操作類別定義為：

$$X_{covered} = X_{fs} \cup X_{proc} \cup X_{net} \cup X_{ipc} \quad (1)$$

非全域介導聲明：本研究明確未主張對未插樁之全量 OS 系統呼叫路徑具備完全介導。

III. 核心安全不變量與安全邊界

A. 形式化不變量定義

- 1) 權限非繼承性公理： $C_A \not\Rightarrow C_E$
- 2) 覆蓋面受約束安全不變量：

$$\forall x \in X_{covered}, \quad Auth_E(x) = DENY \implies Exec_{unauth}(x) = 0 \wedge \Delta S_{S_{obs}} = 0 \quad (2)$$

3) 幽靈系統呼叫觀測神諭：

$$G = \#\{x \in X_{covered} \mid Auth_E(x) = DENY \wedge SyscallObserved(x) = 1\} \quad (3)$$

- 4) 並發撤銷線性化語義：在原子指針切換點 $T_{swap} = 420$ ns 後立即對後續調用確定性生效。

TABLE I
DROS-PGM 安全主張邊界矩陣

主張分類	具體項目與範圍宣告	認識論性質
正式主張	$X_{covered}$ 內 DENY 操作無未授權執行	架構不變量
正式主張	動態撤銷於 T_{swap} 線性化點後立即生效	線性化語義
經驗觀測	評測語料庫中幽靈系統呼叫 $G = 0$	經驗事證
經驗觀測	顯式觀測集合內狀態漂移 $\Delta S = 0$	帶外神諭事證
未主張	全量 OS Syscall 完全介導	超出範圍
未主張	防禦內核 Rootkit 或硬體 MMU 穿透	依賴宿主 TCB
未主張	上游語義授權映射之邏輯正確性	上游治理責任

IV. 威脅模型：後受陷假設 ($C_A = 1$)

- 範圍內能力：應用層全面受陷 ($C_A = 1$)、持有進程內合法 OAuth Token 與 DB 連線、多 Agent 協同攻擊。
- 可信計算基 (TCB)：PGM 二進位閘門、CPU Ring 0/MMU、OS LSM 驅動及防篡改日誌。

V. PGM-VEP 五階漸進式對抗證偽方法學

為落實「無自我作證原則 ($O_I \neq O_A \neq O_E \neq O_P$)」，建立五階驗證階層：

TABLE II
PGM-VEP 驗證階層與開源評測資產對照表

驗證階層	開源執行腳本 / Harness	存證報告與數據路徑
V1 (Baseline)	run_benchmark.py	CYBERMES_REPORT.md
V2 (Search)	stress_test_accelerate.py	EPF_24H_Report.md
V3 (Meta-Test)	conformance_test.py	conformance_report.json
V4 (Oracle)	replay.py	COMPARATIVE_REPORT.md
V5 (Cross-Env)	docker-compose.yml	benchmark_summary.json

VI. 實驗結果與度量分析

A. 評測工作負載會計帳本

TABLE III
評測工作負載會計帳本 (EVALUATION ACCOUNTING MATRIX)

驗證階層	測試類型與配置	總執行次數	反例	判定
V1	B0/B1 等價對照	300	0	PASS
V2	白箱適應性搜尋 (21.4M Tokens)	60,000	0	PASS
V3	5 缺陷二進位 + 100 突變體	105	0	PASS
V4	4 階段事實鏈 + 9 大向量	450	0	PASS
V5	3 大環境設定檔獨立復現	7,500	0	PASS
對抗小計	V1-V5 累積對抗執行	68,355	0	PASS
良性負載	SPEC CPU2017 + 合法調用	50,000	0	BFDR=0
總計	全階層綜合評測	118,355	0	ALL PASS

B. 元驗證結果 (V3)

在 100 個突變體集合中達成 100% 擊殺率 (100/100 Killed, Mutation Score = 1.0)，證實測試框架之缺陷辨識靈敏度。

C. 效能開銷與選定 SPEC CPU2017 基準分解

在 Intel Xeon Gold 6330 上啟用 PGM 之幾何平均開銷為 +1.20% ($\pm 0.12\%$)。在 72 小時連續浸泡測試中，PGM 於 16 個工作執行緒並發負載下保持高達 952,991 QPS 之總體聚合策略決策吞吐量。

TABLE IV
PGM 帶內策略評估延遲全分佈統計 (10^7 次抽樣, 單位: ns)

評測指標	Min	P50	P99	Max	95% CI
C-ABI 策略查表	312	353	412	620	[351, 355]
RCU 切換 (T_{swap})	390	420	438	580	[416, 424]
Fail-Closed 阻絕	410	465	488	640	[462, 468]

TABLE V
執行期安全機制之對抗驗證嚴謹度對照 (METHODOLOGICAL RIGOR)

安全機制類別	攻擊等價	元驗證	解耦神諭	V1-V5 通過
語義護欄 (NeMo)	弱	無	無	否
MCP 政策闡道	部分	無	弱	否
傳統 OS 沙箱	可做	無	弱	否
商業 Endpoint 防護	內部較嚴	未公開	未見	否
Capability Kernel	有	有限	部分	否
DROS-PGM (本研究)	是	是 (100/100)	是	是

VII. 相關工作與分類矩陣

表說明：在現有公開文獻調研範圍內 (*To the best of our survey*)，尚未辨識出其他系統於單一開源包中同時公開上述五項驗證維度。

VIII. 結論與聲明

本文提出並全面評測了 DROS-PGM 二進位執行約束基板，於 118,355 次執行負載中驗證了核心安全不變量。

致謝與 AI 協作聲明 (ACKNOWLEDGMENT & AI DISCLOSURE)

依據 IEEE / ACM 2023+ 指引，作者在此明確揭露：

- 研究原創性與智財權：**本文所述系統架構、雙重邊界、形式化不變量、五階證偽方法學及專利主張 (U.S. PPA No. 64/111,973) 均由作者陳濬程獨立構想與驗證。
- AI 輔助範圍：**LLM 僅作為文法校對、LaTeX 排版與腳本格式化輔助。作者對全文承擔完全之學術與法律責任。

REFERENCES

- 陳濬程, “DROS-PGM: Physical Guard Module with Sub-Microsecond C-ABI Binary Execution Boundary,” *Zenodo Report*, DOI: [10.5281/zenodo.21903687](https://doi.org/10.5281/zenodo.21903687), 2026.
- 陳濬程, “DROS: A Four-Layer Deterministic Runtime Operation System,” *Zenodo Report*, DOI: [10.5281/zenodo.22092008](https://doi.org/10.5281/zenodo.22092008), 2026.
- P. Loscocco and S. Smalley, “Meeting critical security objectives with security-enhanced Linux,” in *Proc. Ottawa Linux Symposium*, 2001.
- W. Drewry, “Chrome sandbox: seccomp-bpf,” *Google Security Blog*, 2012.
- P. E. McKenney, “Is Parallel Programming Hard? (RCU Architecture),” *IBM OS Review*, 2024.
- Agent libOS Team, “Agent libOS: A Library-OS-Inspired Runtime for LLM Agents,” *arXiv:2606.03895*, 2026.
- Authgate Team, “A Capability Kernel for Agent Authorization,” *SSRN:6931639*, 2026.
- AgentVisor Team, “AgentVisor: Defending LLM Agents via Semantic Virtualization,” *arXiv:2604.24118*, 2026.
- MCP Security Group, “Runtime Policy Enforcement for MCP-Based LLM Agents,” *MDPI Electronics*, vol. 15, no. 13, p. 2829, 2026.